

Department: Computer Engineering	Academic Year: 2026-27
Semester: 5	Group No. : TY-A9
Project Title: SCRP: A State-Aware Cybersecurity Reasoning Protocol for Explainable and Audit-Ready AI-Assisted Threat–Risk–Compliance Engineering	
Project Area: Artificial Intelligence, Multi-Agent Systems, and Cybersecurity Engineering for AI-Assisted Threat Analysis, Risk Assessment, and Compliance Mapping.	

Group Members Details:

Sr. No.	Class & Div.	Roll No.	G.R.No.	Name of Student	Contact No.	Email ID
1	CE-A	27	12410361	Shriraj Agarkar	9356773079	shriraj.agarkar24@vit.edu
2	CE-A	28	12412576	Chetan Agrawal	7498126025	chetan.agrawal24@vit.edu
3	CE-A	30	12410897	Manthan Agrawal	8087799750	manthan.agrawal24@vit.edu
4	CE-A	66	12414513	Aryan Ketkar	9422281612	aryan.ketkar24@vit.edu

Name of Internal Guide: Dr. Vidya Gaikwad

Contact No: 7218968723

Email ID: vidya.gaikwad@vit.edu

Project approved / Not

Dr. Vidya Gaikwad
GuideDr. Sheetal Phatangare
Project CoordinatorProf. (Dr.) S.R.Shinde
Head of Department

Project Synopsis:

1. Problem Statement:

The increasing adoption of connected systems such as Internet of Things (IoT) devices, connected vehicles, and cyber-physical systems has significantly expanded the cybersecurity attack surface. Consequently, regulations such as the EU Cyber Resilience Act (CRA) and ISO/SAE 21434 require organizations to perform continuous, traceable, and audit-ready Threat Analysis and Risk Assessment (TARA) throughout the product lifecycle.

However, the existing TARA process faces several critical challenges:

- Threat Analysis, Risk Assessment, and Compliance Mapping are often performed as separate or loosely connected stages, resulting in fragmented cybersecurity decision-making.
- Security engineers must manually correlate information from multiple cybersecurity knowledge bases such as STRIDE, CAPEC, MITRE ATT&CK, CWE, and various security standards, making the process complex, time-consuming, and expertise-intensive.
- Current AI-assisted TARA solutions primarily exchange finalized outputs between stages, often losing reasoning context, supporting evidence, confidence information, and traceability across the cybersecurity decision lifecycle.
- Changes in system design, emerging threats, or compliance requirements require repetitive manual re-analysis, leading to inconsistencies and increased effort.
- Generating explainable, standards-aligned, and audit-ready cybersecurity artefacts for regulations such as ISO/SAE 21434, SESIP, Common Criteria (CC), and the EU Cyber Resilience Act remains largely manual and resource-intensive.

These limitations reduce the efficiency, consistency, explainability, and audit readiness of existing TARA workflows, making it difficult for organizations to effectively manage cybersecurity risks and demonstrate compliance throughout the product lifecycle.

2. Objective:

- To design and formalize the State-Aware Cybersecurity Reasoning Protocol (SCRP) for enabling structured cybersecurity knowledge evolution across the Threat–Risk–Compliance (TRC) lifecycle while preserving reasoning context, evidence, and semantic consistency.
- To develop collaborative Threat, Risk, and Compliance-Mapping agents that perform intelligent cybersecurity reasoning by preserving evidence provenance, confidence information, and mappings to cybersecurity knowledge bases and standards such as STRIDE, CAPEC, MITRE ATT&CK, CWE, ISO/SAE 21434, SESIP, and Common Criteria

- To implement a hybrid reasoning framework with deterministic validation, combining rule-based methods for security-critical risk scoring and standards mapping with LLM-based contextual reasoning for threat analysis, explanation generation, and decision justification.
- To establish an explainable and audit-ready cybersecurity decision framework through end-to-end traceability, consistency checking, and change-impact analysis, ensuring reliable Threat Analysis, Risk Assessment, and Compliance Mapping throughout the TARA lifecycle.

3. Novelty / Research Gap:

Method	Usage Scenario	Strengths	Weaknesses
Manual TARA (ISO/SAE 21434)	Threat Analysis, Risk Assessment and Compliance	Highly accurate and expert-driven decisions	Time-consuming, requires domain experts, difficult to update and maintain throughout the product lifecycle
AI-Based Threat Modelling Systems	Automated threat identification using LLMs and cybersecurity knowledge bases	Faster threat generation, improved coverage, reduced manual effort	Focus mainly on threat identification; limited preservation of reasoning context and downstream decision continuity
AI-Based Risk Assessment Systems	Automated cybersecurity risk scoring	Faster and more consistent risk assessment	Risk decisions are typically isolated from threat reasoning, with limited evidence tracking and lifecycle traceability
AI-Based Compliance Mapping Systems	Mapping cybersecurity risks to security standards	Reduces manual standards mapping effort	Compliance decisions are generally disconnected from upstream threat and risk reasoning, limiting explainability, audit readiness, and change-impact analysis

Proposed SCRP-Based TRC Engine	Collaborative Threat–Risk–Com pliance Reasoning	State-aware knowledge evolution, hybrid deterministic-LL M reasoning, evidence provenance, continuous traceability, explainable multi-standard compliance mapping, and audit-ready cybersecurity artefacts; specifically featuring portfolio-level risk aggregation, business-cost-gro unded impact scoring, cross-standard conflict detection, confidence-gated compliance tiers, and correction-based cross-run learning.	Requires curated cybersecurity knowledge bases, deterministic rule engine, and expert validation for safety-critical decisions
---	---	--	--

- Existing Models:**
- Current AI-assisted Threat Analysis and Risk Assessment (TARA) solutions are fragmented in capability:
- Manual TARA provides accurate security analysis but requires extensive domain expertise, significant time, and repeated manual effort throughout the product lifecycle.
 - AI-based Threat Analysis systems automate threat identification using cybersecurity knowledge bases and LLMs but generally focus only on threat generation with limited downstream reasoning continuity.
 - AI-based Risk Assessment systems improve the speed and consistency of risk evaluation but often lose reasoning context, supporting evidence, and confidence information generated during Threat Analysis.

- AI-based Compliance Mapping systems automate standards mapping (e.g., ISO/SAE 21434, SESIP, Common Criteria) but typically operate independently from upstream Threat and Risk reasoning, limiting explainability, traceability, and audit readiness.

While contemporary AI-driven threat modeling and multi-agent TARA frameworks (such as MAESTRO, ASTRIDE, and STRIDE-AI) have significantly advanced isolated cybersecurity reasoning, they primarily exchange finalized outputs between stages rather than maintaining a continuously evolving cybersecurity reasoning state. The core novelty of this project is systems-integration: applying a formal shared-state protocol (SCRP) to synthesize these active research directions into an end-to-end, CRA-compliant pipeline.

Our Proposed Solution

Our proposed State-Aware Cybersecurity Reasoning Protocol (SCRP) overcomes these limitations by:

- Introducing structured cybersecurity knowledge evolution, allowing Threat, Risk, and Compliance agents to collaboratively build, validate, and progressively enrich a shared cybersecurity reasoning state throughout the complete Threat–Risk–Compliance lifecycle.
- Implementing a Hybrid Deterministic–LLM reasoning framework, where deterministic rule engines perform security-critical operations such as attack feasibility assessment and standards mapping, while LLMs are used for contextual reasoning, threat generation, and explanation.
- Preserving reasoning context, evidence provenance, confidence information, and semantic consistency, ensuring that cybersecurity knowledge is not lost as decisions move across different stages of the TARA process.
- Providing end-to-end bidirectional traceability, consistency checking, and automated change-impact analysis, enabling explainable, standards-aware, and audit-ready cybersecurity artefacts suitable for industrial certification and compliance.
- Supporting explainable multi-standard compliance mapping by generating transparent mappings to ISO/SAE 21434, SESIP, Common Criteria (CC), and other applicable cybersecurity standards with supporting evidence and rationale.
- Executing advanced operational mechanisms to ensure audit-readiness, including portfolio-level risk aggregation, business-cost-grounded impact scoring, cross-standard conflict detection, confidence-gated compliance tiers, and correction-based cross-run learning.

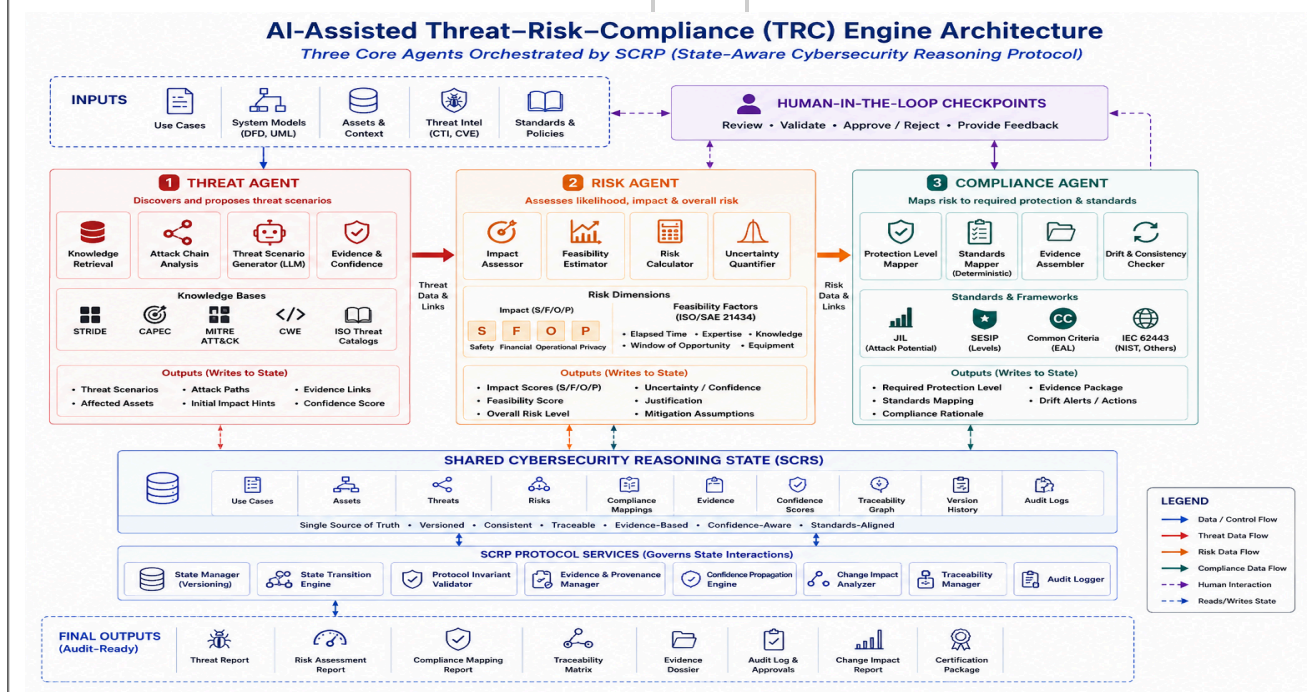
4. Methodology:

- **Requirement Analysis & Knowledge Base Preparation**
 - Study the ISO/SAE 21434 TARA process, industrial cybersecurity requirements, and regulatory standards.
 - Prepare cybersecurity knowledge bases including STRIDE, CAPEC, MITRE ATT&CK, CWE, ISO/SAE 21434, JIL, SESIP, and Common Criteria (CC).

- Define standardized input schemas for system architecture, assets, data flows, and security requirements.
- **Threat Analysis Agent Development**
 - Develop an AI-assisted Threat Agent to identify potential threats using STRIDE, CAPEC, MITRE ATT&CK, and CWE knowledge bases.
 - Generate structured threat scenarios with supporting evidence, confidence scores, and knowledge-base references.
 - Validate generated threats through deterministic checks and maintain structured reasoning information.
- **Risk Assessment Agent Development**
 - Analyze identified threats by evaluating likelihood, impact, and attack feasibility according to ISO/SAE 21434 guidelines.
 - Calculate cybersecurity risk values using deterministic scoring methods supported by AI-generated contextual reasoning, incorporating a configured business-impact cost-band matrix to ground financial (F) and operational (O) impacts in realistic manufacturer costs.
 - Execute a portfolio risk-aggregation pass after individual scoring to cluster and evaluate correlated risks targeting shared system components, ensuring compounded exposures (e.g., multiple "Medium" risks on a single secure element) are accurately surfaced.
 - Preserve threat evidence, confidence information, and reasoning history for downstream decision-making.
- **Compliance Mapping Agent Development**
 - Develop a deterministic Compliance Mapping Agent to map cybersecurity risks to ISO/SAE 21434, SESIP, and Common Criteria (CC) requirements.
 - Generate explainable compliance recommendations, utilizing AI confidence scores as active governance thresholds (e.g., defaulting to stricter regulatory tiers if mapping confidence falls below a predefined limit). Additionally, implement a deterministic conflict-detection check to automatically flag contradictory security controls when mapping risks across multiple concurrent standards.
 - Ensure standards mappings remain consistent with validated Threat Analysis and Risk Assessment results.
- **State-Aware Cybersecurity Reasoning Protocol (SCRCP)**
 - Implement the State-Aware Cybersecurity Reasoning Protocol (SCRCP) to enable collaborative reasoning among Threat, Risk, and Compliance agents.
 - Preserve cybersecurity knowledge through a shared reasoning state containing evidence, confidence information, reasoning history, and standards mappings.
 - SCRCP defines the shared state schema and data interfaces (traceability links, audit records, change-impact events) that the Threat, Risk, and Compliance agents write to; full audit-report generation and system-wide consistency checking remain the responsibility of the downstream TARA pipeline stages.

- Enforce a per-agent validation gate via the Protocol Invariant Validator: each agent's output must pass its own automated test cases (e.g., citation presence, schema completeness, consistency with prior-stage data) before being released to the Human-in-the-Loop checkpoint. On failure, the agent retries by re-invoking both its evidence retrieval and its reasoning steps — using the failed output and the specific failure reason as added context — rather than regenerating blind, capped at a fixed number of attempts (e.g. three) before escalating directly to human review as a flagged failure. Only after the output clears both the automated test-case gate and human approval does it advance to the next agent.
 - Incorporate a continuous cross-run learning mechanism that logs expert "Human-in-the-Loop" overrides and their justifications into a vector database. This mechanism actively refines future runs by reranking retrieved knowledge-base patterns and injecting past correction context directly into the agent's reasoning prompt to prevent repeated errors.
- System Evaluation & Validation**
 - Validate the proposed framework using representative IoT and cyber-physical system case studies.
 - Compare the outputs of the proposed SCRP framework against a manually authored, ground-truth reference TARA (e.g., an expert-validated baseline for a Smart Door Lock) to report empirical, quantitative metrics for reasoning consistency, traceability completeness, standards mapping accuracy, and audit readiness.
 - Analyze the effectiveness of the proposed methodology in generating explainable, standards-aligned, and audit-ready cybersecurity artefacts.

Proposed System Architecture:



5. Expected Outcomes:

- Development of a State-Aware Cybersecurity Reasoning Protocol (SCRP) that enables structured cybersecurity knowledge evolution across the Threat–Risk–Compliance (TRC) lifecycle.
- An intelligent AI-assisted TRC Engine comprising specialized Threat Analysis, Risk Assessment, and Compliance Mapping agents capable of collaboratively generating consistent and explainable cybersecurity decisions.
- Preservation of reasoning context, evidence provenance, confidence information, and standards mappings throughout the cybersecurity decision lifecycle, ensuring semantic consistency and reducing information loss between stages.
- Generation of standards-aligned and audit-ready cybersecurity artefacts with bidirectional traceability, automated change-impact analysis, and explainable compliance recommendations for standards such as ISO/SAE 21434, SESIP, and Common Criteria (CC).
- A validated framework that demonstrates improved reasoning consistency, traceability, explainability, and lifecycle management compared to conventional AI-assisted TARA approaches, providing a strong foundation for industrial cybersecurity engineering and future research.

6. Hardware and Software Specifications:

Hardware Requirements

For Development & Testing Environment:

- **Processor:** Intel Core i5 (10th Gen) or higher / AMD equivalent
- **RAM:** Minimum 8 GB (16 GB recommended for AI model training)
- **Storage:** 512 GB SSD or higher
- **GPU: (Optional):** NVIDIA GPU with CUDA support (e.g., GTX 1660 or higher) strictly for running local embedding models for knowledge-base vector search. Core LLM reasoning is handled externally via the OpenAI API.
- **Internet:** Stable broadband connection (minimum 10 Mbps)

Software Requirements

- **Operating System (Development):** Windows 10/11
- **Programming Languages:** Python 3.11+, JavaScript (ES6), TypeScript
- **Frameworks & Libraries:**
 - **Backend:** FastAPI (Python)
 - **Frontend:** React.js
 - **AI Orchestration:** LangGraph, LangChain
 - **LLM Integration:** OpenAI API
 - **Vector Search:** FAISS
 - **Data Processing:** Pandas, NumPy

- **API Validation:** Pydantic
- **Database:** PostgreSQL
- **Knowledge Bases:** STRIDE, CAPEC, MITRE ATT&CK, CWE
- **Cybersecurity Standards:** ISO/SAE 21434, JIL, SESIP, Common Criteria (CC), EU Cyber Resilience Act (CRA)
- **Version Control:** Git & GitHub
- **IDE / Tools:** Visual Studio Code, Postman
- **Deployment:** Docker
- **Browser Compatibility:** Google Chrome, Mozilla Firefox, Microsoft Edge (Latest Versions)

7. Limitations:

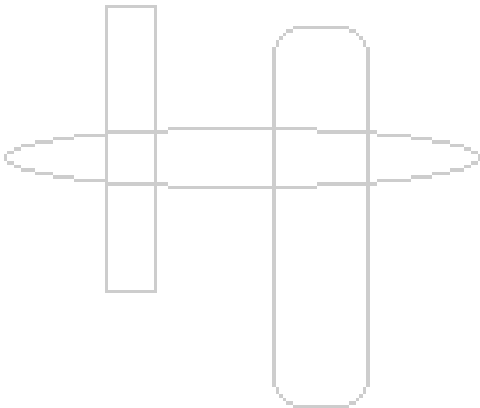
- The proposed framework is evaluated on selected IoT and cyber-physical system case studies; its applicability to other domains may require additional domain-specific knowledge bases and standards.
- The performance and quality of AI-generated reasoning depend on the capabilities of the underlying Large Language Model (LLM) and the completeness of the integrated cybersecurity knowledge bases.
- The Compliance Mapping Agent is implemented and demonstrated for ISO/SAE 21434, SESIP, and Common Criteria (CC). While the SCRP architecture is designed to be extensible to additional frameworks such as IEC 62443 and NIST, full mapping-rule coverage for these is left as future work.
- The proposed framework assists cybersecurity experts in Threat Analysis, Risk Assessment, and Compliance Mapping but does not replace human expert validation, particularly for safety-critical and regulatory certification decisions.
- The accuracy of the generated cybersecurity artefacts depends on the quality and completeness of the input system information provided during the TARA process.

8. Conclusion:

The proposed research presents a State-Aware Cybersecurity Reasoning Protocol (SCRP) to enhance AI-assisted Threat Analysis, Risk Assessment, and Compliance Mapping within the Threat–Risk–Compliance (TRC) lifecycle. By enabling structured cybersecurity knowledge evolution, preserving reasoning context, evidence provenance, confidence information, and standards alignment, the proposed framework aims to generate consistent, explainable, and audit-ready cybersecurity artefacts. The research is expected to improve the efficiency, traceability, and reliability of AI-assisted TARA while supporting compliance with cybersecurity standards such as ISO/SAE 21434, SESIP, and Common Criteria (CC), thereby contributing to more effective and trustworthy cybersecurity engineering practices.

Group No.	TY-A9		
Activity	Review Schedule	Progress Review Report submitted	Signature of Guide
Review 1	Mid Semester	Yes / No	
Review 2	End of Semester	Yes / No	

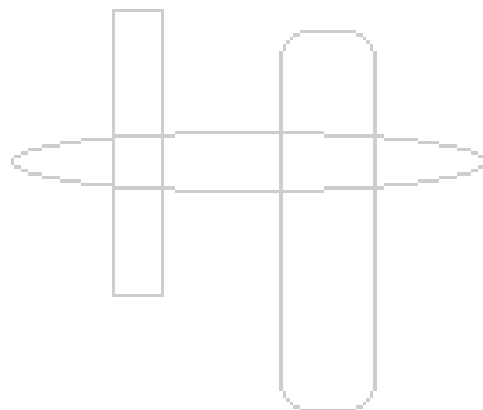
Format of Progress Review Report:

Review No.: 1	Group No.: TY-A9	Date:
Progress Review Report		
		
Signature of Guide:		

Review No.: 2

Group No.: TY-A9

Date:



Signature of Guide: